

DLP trong Big Data

Ngăn ngừa rò rỉ dữ liệu

Giảng viên hướng dẫn:
PGS.TS. Đặng Trần Khánh
TS. Phạm Thị Bạch Huệ
ThS. Lương Vĩ Minh

25C12011 - Nguyễn Bảo Trâm
25C11012 - Võ Công Minh
25C12016 - Trần Huy Vũ
25C12031 - Dương Tấn Huỳnh Phong

Date: 29/09/2026

Mục Lục



1. Bài toán bảo mật Big Data



2. Cơ chế DLP trong Big Data



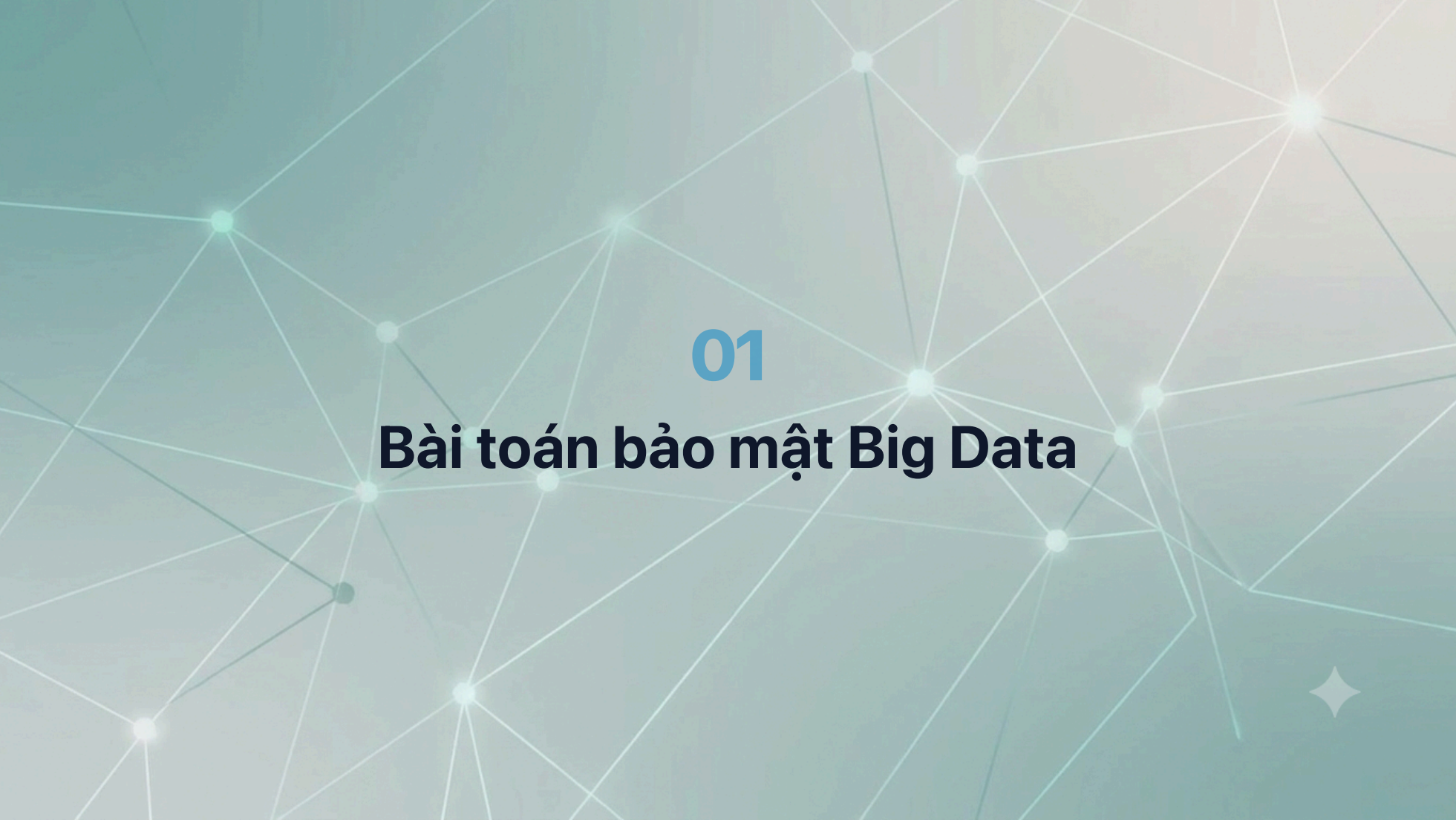
3. Giải pháp và xu hướng DLP



4. Demo và đánh giá



5. Giới hạn và kết luận



01

Bài toán bảo mật Big Data



Big Data: Luồng dữ liệu & Nguy cơ rò rỉ

Đặc thù khối lượng lớn, tốc độ cao và đa dạng (3V) - dữ liệu luân chuyển liên tục qua nhiều tầng xử lý để tạo ra các bảng tổng hợp phục vụ phân tích.



1. Quyền truy cập (Access Control)

Cụm phân tán nhiều người dùng, khó kiểm soát chi tiết và dễ bị cấp dư quyền.

2. Tính toàn vẹn (Integrity)

Nguồn dữ liệu đa dạng, dễ bị sai lệch hoặc can thiệp trong các tầng xử lý.

3. Tính sẵn sàng (Availability)

Hạ tầng phân tán quy mô lớn dễ gặp sự cố quá tải hoặc nghẽn dịch vụ.

4. Rò rỉ dữ liệu (Data Leakage) - Trọng tâm

Bản sao sau xử lý bị trích xuất và gửi ra kênh ngoài chưa kiểm duyệt.

Đọc đúng quyền, nhưng gửi sai đích?

Tình huống thực tế: Người dùng thực hiện thao tác nghiệp vụ hợp lệ nhưng vẫn tạo ra nguy cơ rò rỉ dữ liệu.



1. Thao tác nghiệp vụ hợp lệ

Chuyên viên dữ liệu được cấp quyền đọc thông tin khách hàng từ Data Lake.

Chạy truy vấn tạo bảng tổng hợp `customer_segments` để phục vụ công việc.

⚠️ Bảng kết quả sau xử lý vô tình vẫn còn thông tin định danh cá nhân: **Mã KH, Email, SĐT (PII)**.

2. Nguy cơ khi chia sẻ ra ngoài

Tập dữ liệu này được xuất và gửi sang **kênh bên ngoài chưa được kiểm duyệt** (đám mây cá nhân, đối tác).

Điểm mù bảo mật: Hệ thống chỉ kiểm soát quyền lúc đọc vào, nhưng bỏ ngỏ nội dung tập khi xuất ra ngoài!

Làm sao tự động nhận diện PII trong tập gửi đi để ngăn chặn kịp thời? → Đó là vai trò của DLP.

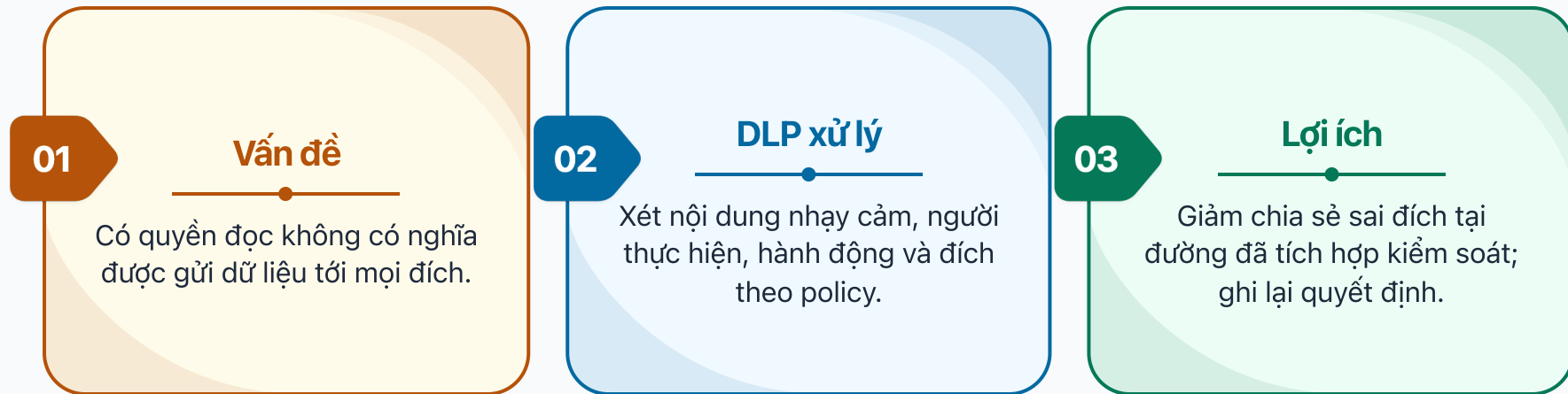


02

Cơ chế DLP trong Big Data

DLP là gì?

Data Loss Prevention (DLP) nhận diện dữ liệu nhạy cảm và áp dụng policy để kiểm soát việc sử dụng, chia sẻ hoặc xuất dữ liệu.



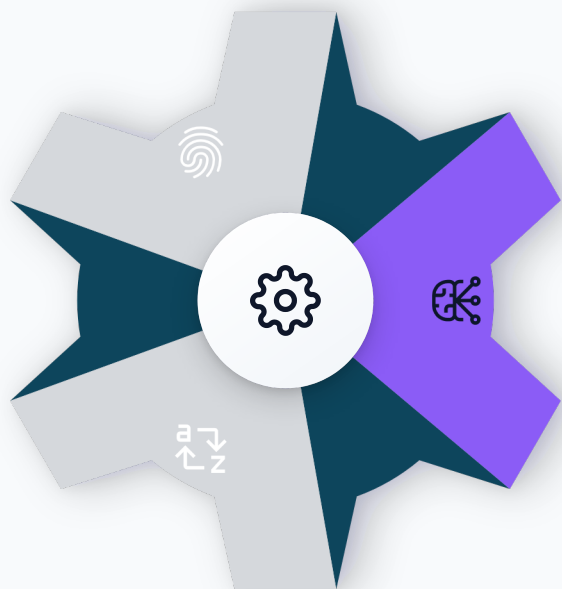
DLP trong Defense-in-Depth (DiD)



Policy, đào tạo, Audit & Monitoring hỗ trợ xuyên suốt.

DLP bổ sung kiểm soát nội dung và cách chia sẻ dữ liệu tại nhiều lớp.

Ba cách tìm nội dung nhạy cảm



Ngữ cảnh (AI/ML)

Phân loại theo ngữ cảnh

Cơ chế: Dùng mô hình để đánh giá nội dung trong ngữ cảnh.

Ví dụ minh họa: 'Lan đang điều trị bệnh X.' → thông tin sức khỏe gắn với cá nhân.

Giới hạn: Có thể báo nhầm/bỏ sót; cần kiểm thử trên dữ liệu thực tế.

Phát hiện cung cấp đầu vào cho policy; chặn cần điểm thực thi.

DLP trong pipeline Big Data



Chặn chỉ có hiệu lực tại đường đã tích hợp kiểm soát.

Thách thức: quy mô lớn · đa định dạng · dữ liệu biến đổi · nhiều đường xuất.



03

Giải pháp và xu hướng DLP

Giải pháp DLP cho Big Data

Phân quyền, masking và audit là nền tảng; DLP bổ sung kiểm soát dữ liệu nhạy cảm.

	Amazon Macie Amazon S3	Microsoft Purview DLP Fabric / Power BI	Sensitive Data Protection Google Cloud
Phạm vi	Đối tượng S3 được hỗ trợ.	Các loại mục và dữ liệu được hỗ trợ trong Fabric / Power BI.	BigQuery, Cloud Storage và dữ liệu gửi qua API.
Khả năng chính	Phát hiện dữ liệu nhạy cảm ; tạo kết quả phát hiện (findings).	Thông báo policy, cảnh báo ; hạn chế truy cập (preview).	Kiểm tra dữ liệu nhạy cảm ; khử định danh.
Ranh giới kiểm soát	Findings cần gắn với quy trình xử lý hoặc biện pháp thực thi.	Hạn chế truy cập vào mục; không bao phủ mọi đường xuất.	Kiểm tra và khử định danh cần tích hợp vào luồng dữ liệu.

Nguồn: [AWS](#) · [Microsoft Learn](#) · [Google Cloud](#)

Phát hiện, khử định danh và hạn chế truy cập là các khả năng khác nhau.

AI hỗ trợ DLP ở đâu?

HỖ TRỢ HUẤN LUYỆN

Tạo dữ liệu tổng hợp

LLM tạo văn bản tổng hợp tiếng Ý để huấn luyện bộ phát hiện dữ liệu nhạy cảm.

LLM → Văn bản tổng hợp → Huấn luyện bộ phát hiện

De Renzis et al. (2024)

HỖ TRỢ PHÁT HIỆN

Nhận diện theo ngữ cảnh

Nhận diện thông tin nhạy cảm phụ thuộc ngữ cảnh trong văn bản phi cấu trúc.

So sánh các mô hình ML và transformer cho bài toán phát hiện.

Qawara & Alhindi (2026)

Minh họa tích hợp trong DLP



Cần đánh giá lại trên dữ liệu đích: báo nhầm, bỏ sót và độ trễ.



04

Demo và đánh giá



Bối cảnh và mục tiêu

1 Yêu cầu

2 Dữ liệu

3 Phát hiện

4 Quyết định

5 Chia sẻ

DỮ LIỆU CỦA CÔNG TY

Data Lake và Spark

Một triệu hồ sơ khách hàng, gồm thông tin liên hệ, giao dịch và ghi chú hỗ trợ.



NGƯỜI THỰC HIỆN

Phong, chuyên viên dữ liệu

Phong có quyền đọc dữ liệu và chạy Spark để chuẩn bị báo cáo.



NHU CẦU TỪ ĐỐI TÁC

Báo cáo phân khúc

Đối tác chỉ cần số khách hàng theo vùng và phân khúc.

VẤN ĐỀ HIỆN TẠI

Phong có thể xuất một file chứa toàn bộ dữ liệu khách hàng, dù đối tác chỉ cần số liệu tổng hợp.

MỤC TIÊU DEMO

DLP kiểm tra file trước khi dữ liệu rời khỏi công ty và vẫn cho phép gửi báo cáo phù hợp.

Dữ liệu chuẩn bị gửi

- 1 Yêu cầu
- 2 Dữ liệu
- 3 Phát hiện
- 4 Quyết định
- 5 Chia sẻ

Ba dòng trích từ customer_segments

customer_id	email	phone	region	campaign_code	support_note
CUS-00000000	customer0@example.test	0900000000	HCM	AURORA-2026	Đang mang thai, cần giao hàng tại nhà.
CUS-00000001	customer1@example.test	0900000001	HN	PUBLIC-CAMPAIGN	Hỏi về chương trình tích điểm.
CUS-00000002	customer2@example.test	0900000002	DN	PUBLIC-CAMPAIGN	Hỏi về chương trình tích điểm.

Thông tin cá nhân

Email, số điện thoại

Thông tin nội bộ

Mã chiến dịch chưa công bố

Thông tin sức khỏe

Nằm trong câu ghi chú tự do

DLP kiểm tra dữ liệu

1 Yêu cầu

2 Dữ liệu

3 Phát hiện

4 Quyết định

5 Chia sẻ

DỮ LIỆU NHÌN THẤY

customer0@example.test
0900000000

AURORA-2026

"Đang mang thai, cần giao hàng tại nhà."

AI chỉ bổ sung tín hiệu còn thiếu. Quyết định cho phép hay chặn vẫn do policy của tổ chức đưa ra.

CÁCH KIỂM TRA

Quy tắc định dạng
Nhận ra email và số điện thoại

Fingerprint
So với mẫu nội bộ đã đăng ký

AI đọc ngữ cảnh
Nhận ra ý nghĩa của câu tự do

KẾT QUẢ

THÔNG TIN CÁ NHÂN

THÔNG TIN NỘI BỘ

THÔNG TIN SỨC KHỎE

Nơi nhận dữ liệu

1 Yêu cầu

2 Dữ liệu

3 Phát hiện

4 Quyết định

5 Chia sẻ

Phong gửi `customer_segments` — file có thông tin cá nhân, nội bộ và sức khỏe

TRƯỜNG HỢP A

Gửi vào kho phân tích nội bộ

Nơi nhận đã được công ty phê duyệt

CHO PHÉP

Dữ liệu vẫn nằm trong phạm vi kiểm soát.

TRƯỜNG HỢP B

Gửi sang ổ đĩa của đối tác

Nơi nhận nằm ngoài công ty

CHẶN

DLP dừng thao tác trước khi file được ghi.

Quyết định phụ thuộc vào nội dung file, người gửi, hành động và nơi nhận.

Dữ liệu được phép chia sẻ

- 1 Yêu cầu
- 2 Dữ liệu
- 3 Phát hiện
- 4 Quyết định
- 5 Chia sẻ

customer_segments

1.000.000 dòng chi tiết
Email · SĐT · mã nội bộ · ghi chú

KHÔNG GỬI



CHỈ GIỮ
PHẦN CẦN
THIỆT

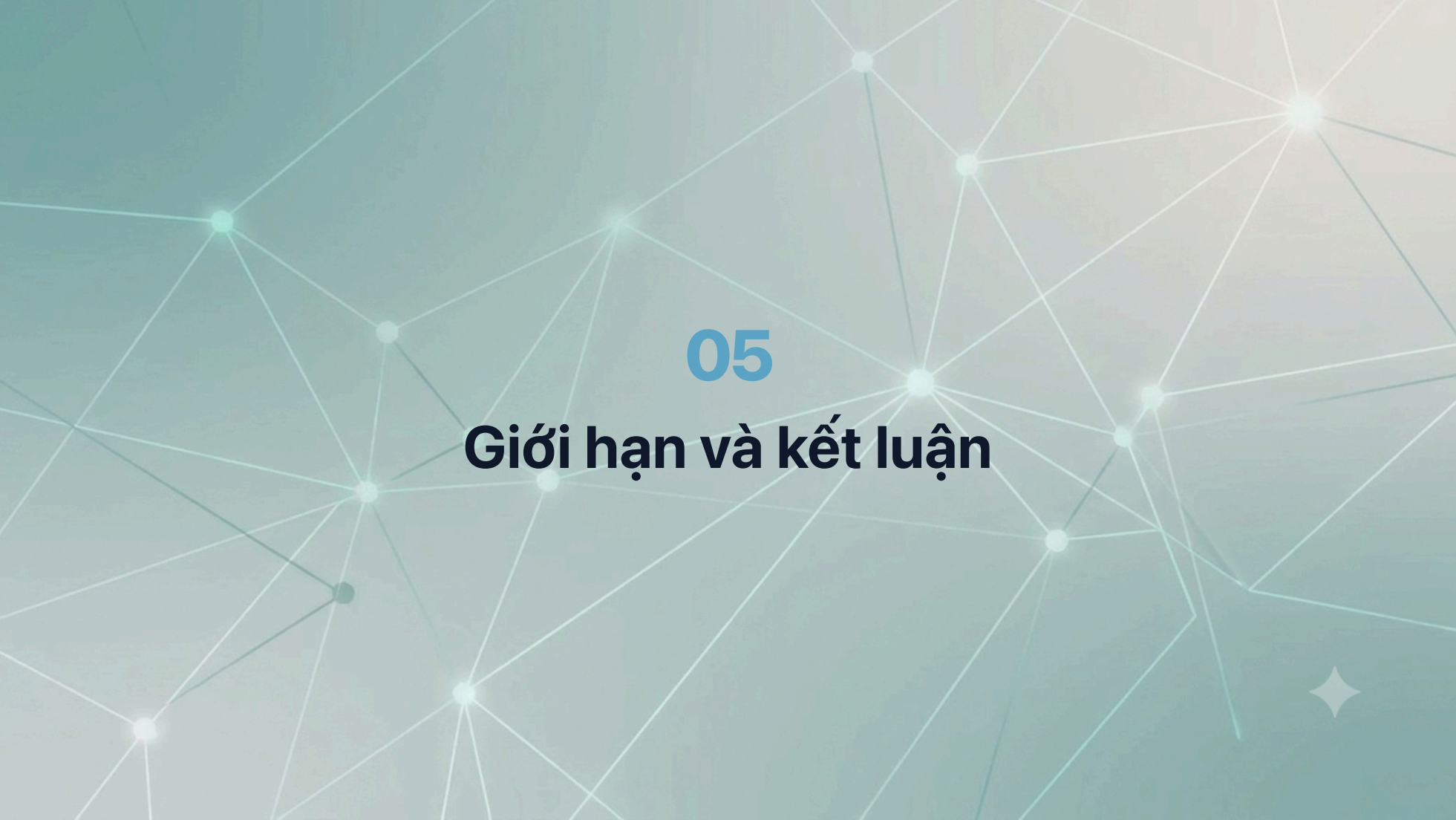
segment_summary

Bảng tổng hợp mới

CHO PHÉP

region	segment	customer_count	average_spend
DN	gold	333.333	49.999,55
HCM	bronze	333.334	49.999,50
HN	silver	333.333	49.999,45

DLP cho phép gửi đúng phần dữ liệu mà đối tác cần.



05

Giới hạn và kết luận

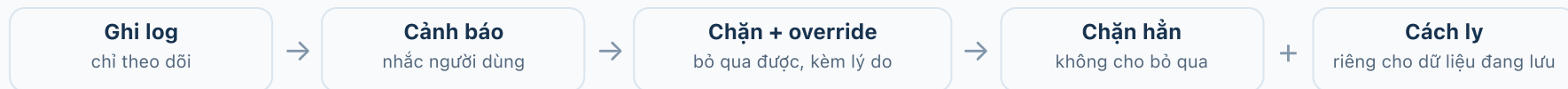


Ưu điểm của DLP

Access control trả lời “ai được đọc?”; DLP trả lời thêm “nội dung này được phép gửi đi đâu?”



CÁC MỨC XỬ LÝ ĐIỂN HÌNH - VÍ DỤ MICROSOFT PURVIEW



Big Data: quét rò rỉ phân tán là khả thi; prototype MapReduce/Hadoop trên 24 node đạt 225 Mbps (Liu et al., 2015) - mới là nghiên cứu, chưa phải sản phẩm.

DLP bổ sung cho phân quyền, mã hóa và masking, chứ không thay thế chúng.

Hạn chế: giảm rủi ro, không loại bỏ rủi ro

	Vì sao xảy ra	Cách giảm thiểu
1 - Báo nhầm / bỏ sót (FP/FN)	Rule, fingerprint, AI đều có sai số ; dữ liệu mã hóa hoặc cổ tình biến dạng khó phát hiện.	Chạy chế độ mô phỏng trước khi chặn thật; tinh chỉnh; đo FP/FN.
2 - Egress path chưa kiểm soát	Egress path là đường để dữ liệu rời hệ thống : upload qua trình duyệt, đọc thẳng storage, script đi vòng.	Kiểm soát từng egress path ; quét lại dữ liệu dẫn xuất.
3 - Phạm vi hỗ trợ của sản phẩm	Mỗi dịch vụ chỉ hỗ trợ một số loại dữ liệu, định dạng (vd: Model Armor bỏ qua tệp > 4 MB, không hỗ trợ audio/video).	Lập bảng độ bao phủ ; kết hợp nhiều lớp phòng thủ (defense in depth).
4 - Chi phí vận hành	Soạn policy, đổi quy trình, đào tạo người dùng.	Triển khai theo pha: ghi log → cảnh báo → chặn .
5 - Độ trễ và quy mô	Mỗi lần kiểm tra tốn thời gian; nhiều định dạng, nhiều egress path .	Đo thời gian quét và độ trễ ra quyết định .

INSIDER - NGƯỜI CÓ QUYỀN HỢP LỆ

Tổng quan 42 nghiên cứu (2011-2022) coi rò rỉ do **người có quyền hợp lệ**, cố ý hoặc vô ý, là mối quan tâm chính; ~40% nghiên cứu tập trung vào insider. DLP **giảm chứ không loại bỏ** rủi ro này và phụ thuộc nhiều vào chất lượng policy.

Herrera Montano et al., 2022

☐ Giới hạn cốt lõi của đề xuất

Cần đo: FP/FN — Độ trễ — Độ bao phủ

Ứng dụng và xu hướng

ĐÃ CÓ TRONG THỰC TẾ

Amazon Macie

Khám phá dữ liệu nhạy cảm trong Amazon S3, tạo findings.

Purview DLP

Policy tips, cảnh báo; hạn chế truy cập (preview) - áp dụng cho Fabric / Power BI.

Sensitive Data Protection

Kiểm tra và khử định danh (de-identify) dữ liệu - trên Google Cloud.

XU HƯỚNG 2025-2026

DLP cho AI tạo sinh (GenAI)

Purview DLP (preview) bảo vệ prompt gửi Microsoft 365 Copilot; policy mặc định chỉ ghi log ở chế độ mô phỏng, phải bật enforce mới chặn.

Bảo vệ prompt và phản hồi AI

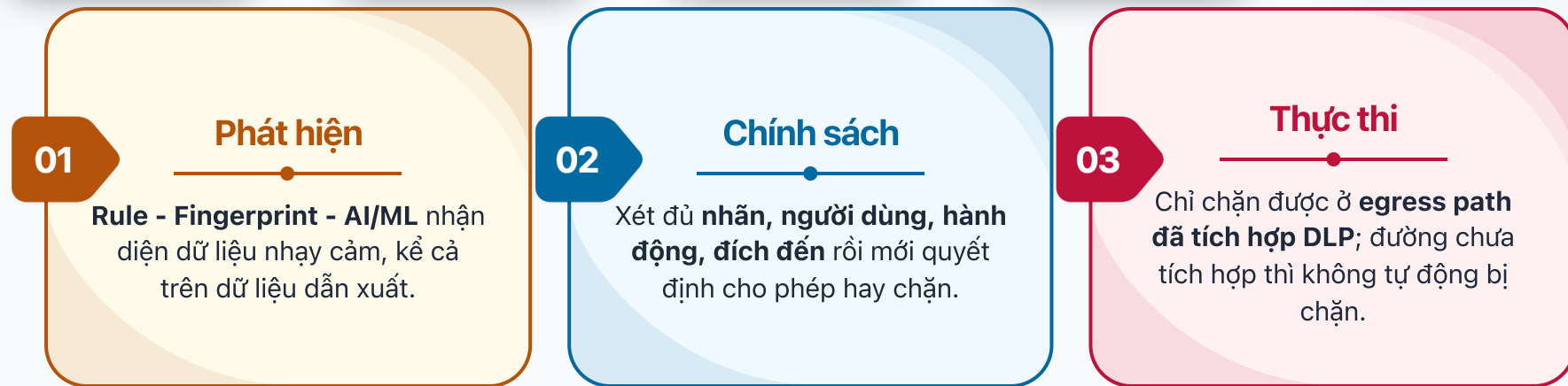
Google Model Armor + Sensitive Data Protection lọc dữ liệu nhạy cảm trong prompt và phản hồi; có chế độ chỉ ghi log hoặc chặn.

AI hỗ trợ phát hiện

De Renzis (2024): LLM sinh dữ liệu tổng hợp để huấn luyện bộ phát hiện (tiếng Ý, F1 > 90%). Qawara & Alhindi (2026): 3.083 tweet tiếng Anh; mô hình đơn giản (LR) ngang DistilRoBERTa.

Xu hướng: từ “quét tập” sang bảo vệ luồng dữ liệu, kể cả prompt AI.

Kết luận



Bổ sung cho phân quyền và mã hóa, không thay thế

Phân loại cả dữ liệu dẫn xuất

Cần đo FP/FN - độ trễ - độ bao phủ

Quyền đọc hợp lệ $\neq$ quyền gửi đi bất cứ đâu.

References

Alneyadi et al. (2016)

A survey on data leakage prevention systems

Liu et al. (2015)

Privacy-Preserving Scanning of Big Content for Sensitive Data Exposure with MapReduce

Shapira et al. (2013)

Content-based data leakage detection using extended fingerprinting

Ahmed et al. (2021)

Automated detection of unstructured context-dependent sensitive information using deep learning

Schwab et al. (2021)

Performance Evaluation of Policy-Based SQL Query Classification for Data-Privacy Compliance

Herrera Montano et al. (2022)

Survey of Techniques on Data Leakage Protection and Methods to address the Insider threat

De Renzis et al. (2024)

Exploiting Large Language Models to Train Automatic Detectors of Sensitive Data

Qawara & Alhindi (2026)

Detecting Context-Dependent Sensitive Data in Unstructured Text



Thank You
for your attention!